ЛЕКЦІЯ 12
ДЕПАРТАМЕНТ ІНФОРМАЦІЙНОЇ БЕЗПЕКИ І РОБОТА З ПЕРСОНАЛОМ

В лекції описується робота департаменту інформаційної безпеки як основної структурної одиниці, що відповідає за комплексний захист інформації на підприємстві. Розкривається внутрішня структура департаменту, основні завдання та напрями його діяльності, методи роботи. Також розкриваються основні аспекти роботи з персоналом підприємства, спрямованої на захист інформаційних активів (як в частині підбору і розстановки співробітників, пов'язаних з обробкою інформації, так і в частині поточної роботи з персоналом).

Ключові слова: управління інформаційної безпекою, CISO, джерело загрози, інформаційні системи, державна таємниця, державна стратегія, аналіз, контроль поведінки, розподіл функцій, доступ, зловмисник.

План

12.1. Департамент інформаційної безпеки

12.2. Організаційна структура та персонал департаменту інформаційної безпеки

12.3. Робота з персоналом підприємства

12.1. Департамент інформаційної безпеки

Департамент інформаційної безпеки (далі – департамент) підприємства є самостійним структурним підрозділом підприємства, безпосередньо виконує ключові функції захисту інформаційних ресурсів.

Його основними завданнями, як правило, є:

- організація та координація робіт із забезпечення комплексного захисту інформації на підприємстві;
- контроль за виконанням встановлених вимог та оцінка ефективності

роботи підрозділів і персоналу підприємства щодо забезпечення інформаційної безпеки;

- виконання окремих адміністративних і технічних функцій щодо забезпечення інформаційної безпеки;
- формування, підтримка та документальне забезпечення політики інформаційної безпеки на всіх рівнях;
- впровадження різних засобів захисту інформації;
- адміністрування окремих інформаційних систем.

Склад завдань департаменту і його внутрішня організаційна структура в кожному конкретному випадку визначається такими особливостями функціонування підприємства, як:

- значимість інформаційних ресурсів у роботі підприємства і характер існуючих загроз;
- ставлення керівництва і власників підприємства до питань інформаційної безпеки та їх управлінська кваліфікація;
- функціональність і характер використовуваних інформаційних систем, їх роль у бізнес-процесах;
- організація роботи та структура IT-служби;
- фінансовий стан підприємства.

Таким чином, рішення про склад і структуру департаменту в кожному випадку має бути індивідуальним і враховує всі основні умови.

Функції, пов'язані **з формуванням, підтримкою і документальним забезпеченням політики інформаційної безпеки підприємства,** можуть включати в себе:

- консультування керівників і власників підприємства з питань розробки та вдосконалення політики інформаційної безпеки;
- самостійну розробку політики безпеки, її узгодження і подання її керівництву підприємства для затвердження, а також внесення необхідних змін у міру зміни умов роботи підприємства;
- самостійну розробку політик безпеки, що стосуються окремих питань

захисту інформації (правил застосування телекомунікаційних технологій, вимог, обов'язкових для всіх персональних комп'ютерів, що використовуються на підприємстві, тощо);

- формування вимог і регламенту процедур перегляду політики безпеки, окремих правил, типових форм та інших документів;
- аналіз окремих договорів і угод зі сторонніми організаціями (постачальниками, покупцями, партнерами по проведенню науково-дослідних робіт тощо) на предмет відповідності вимогам політики інформаційної безпеки;
- аналіз та узагальнення передового досвіду та сучасних теорій у сфері управління інформаційною безпекою з метою їх практичного застосування на підприємстві;
- залучення сторонніх фахівців, дослідників, консультантів (консалтингових компаній) для розробки та вдосконалення політики безпеки підприємства та впровадження розвинених методів управління в цій сфері;
- управління навчанням персоналу компанії (контроль за повнотою та правильністю матеріалів навчальних програм, пов'язаних з інформаційною безпекою, забезпечення своєчасності проходження навчання тощо);
- консультування фахівців та керівників підрозділів підприємства з питань відповідності розроблюваних внутрішніх документів окремих підрозділів вимогам політики безпеки підприємства;
- контроль відповідності внутрішніх організаційних документів підприємства (правил внутрішнього розпорядку, посадових інструкцій, інструкцій з використання інформаційних систем, типових форм договорів тощо) вимогам політики інформаційної безпеки, а також узгодження таких документів при їх затвердженні.

Функції, пов'язані з **впровадженням засобів захисту інформації,** можуть включати в себе:

- аналіз сучасних програмних і апаратних засобів захисту інформації та пов'язаних з ними методик захисту, а також ринку доступних засобів захисту інформації, що застосовуються для різних цілей, і підготовка обгрунтованих пропозицій щодо придбання певних продуктів у певних постачальників;
- аналіз закуповуваних інформаційних систем (операційних систем, прикладних програм, телекомунікаційного устаткування, обчислювальної техніки тощо) на предмет їхньої потенційної надійності і наявності вразливостей;
- залучення сторонніх експертів і консультантів для аналізу закуповуваних і використовуваних засобів захисту інформації з точки зору їх надійності, а також з точки зору доцільності їх застосування (впровадження);
- формулювання вимог (пов'язаних із забезпеченням інформаційної безпеки) до самостійно розроблюваних програмних продуктів або програмного забезпечення, що створюється на замовлення сторонніх розробників;
- участь у проектуванні нових інформаційних систем, а також тестуванні знову розроблених і впроваджуваних програмних продуктів;
- розробку техніко-економічного обґрунтування для проектів впровадження засобів захисту інформації, а також залучення для цих цілей сторонніх аналітиків і консультантів, що спеціалізуються на питаннях аналізу засобів захисту інформації;
- підготовку обгрунтованих рішень про вибір між самостійною розробкою засобів захисту інформації (наприклад, програмних модулів, що здійснюють шифрування даних) і передачею їх розробки стороннім компаніям.

Функції, пов'язані з адмініструванням **інформаційних систем і систем захисту інформації** можуть включати в себе:

- виконання деяких функцій з адміністрування окремих інформаційних систем (баз даних, систем колективної роботи з документами, поштових систем тощо), а також адміністрування та конфігурування систем захисту інформації (міжмережевих екранів, систем виявлення вторгнень тощо);
- визначення необхідних типових налаштувань і конфігурацій робочих станцій (персональних комп'ютерів), що мають відношення до інформаційних систем підприємства (зокрема, підключених до його локальної мережі);
- залучення сторонніх організацій для здійснення поточного адміністрування інформаційних систем і систем захисту інформації, а також для консультаційної та технічної підтримки при виникненні інцидентів, пов'язаних з інформаційною безпекою (зокрема, при здійсненні нападів на інформаційні системи підприємства);
- установку (в тому числі і спільно з фахівцями IT-підрозділу) програмних і апаратних засобів захисту інформації на робочі місця користувачів і в інші елементи інформаційних систем;
- консультування користувачів з питань, пов'язаних з інформаційною безпекою, і оперативне вирішення проблем;
- реагування на різні інциденти, пов'язані з порушенням інформаційної безпеки;
- прийняття активних зустрічних заходів при виявленні вторгнень в інформаційну систему (інформування правоохоронних органів, самостійний пошук нападників тощо);
- генерування паролів користувачів інформаційних систем та забезпечення їх збереження;
- участь у відновленні працездатності інформаційних систем після збоїв та порушень у роботі.

Функції, пов'язані з **контролем виконання вимог політики інформаційної безпеки та проведення аудитів** можуть включати в себе:

- збір та аналіз відомостей про порушення різних вимог політики

безпеки, що надходять з різних джерел (у тому числі і від адміністраторів інформаційних систем) і визначення пріоритетних напрямів контрольної роботи;

- перевірку організаційної документації окремих підрозділів підприємства на предмет відповідності вимогам політики інформаційної безпеки (у тому числі і своєчасності внесення всіх необхідних змін до чинних внутрішніх документів організації);
- перевірку стану (правильності ведення) поточної господарської та кадрової документації окремих підрозділів підприємства, пов'язаної із забезпеченням інформаційної безпеки (правильності і своєчасності заповнення журналів, своєчасність оформлення зобов'язань про нерозголошення відомостей співробітниками тощо);
- проведення комплексних аудитів інформаційної безпеки на підприємстві;
- організацію контрольних перевірок захищеності окремих елементів інформаційних систем (серверів, сегментів мережі тощо);
- залучення сторонніх організацій для проведення аудитів інформаційної безпеки на підприємстві, перевірок надійності інформаційних систем.

Крім перерахованих функцій, безпосередньо пов'язаних із захистом інформаційних ресурсів, також велике значення має виконання функцій, пов'язаних з охороною майна підприємства і вирішенням завдань, які пов'язані з забезпеченням безпеки підприємства у більш широкому сенсі. Зокрема, для забезпечення інформаційної безпеки має значення виконання таких функцій як:

- охорона території та майна підприємства, а також охорона персоналу;
- забезпечення дотримання пропускного режиму;
- спостереження за територією і приміщеннями (у тому числі за допомогою відеокамер);
- контроль за ввезенням на територію підприємства та вивезенням готової продукції, матеріалів, документів та іншого майна;
- організацію внутрішніх службових перевірок та розслідувань, а також

взаємодію з правоохоронними органами;

- контроль за дотриманням тимчасового режиму роботи, а також за дотриманням правил внутрішнього розпорядку.

12.2. Організаційна структура та персонал департаменту інформаційної безпеки

На практиці департамент є підрозділом, або безпосередньо підпорядковується першій особі підприємства, або входить, як структурна одиниця, в службу безпеки підприємства. Співробітники департаменту знаходяться в адміністративному та функціональному підпорядкуванні у керівника департаменту, який несе відповідальність за забезпечення інформаційної безпеки на підприємстві. Висновок департаментів інформаційної безпеки зі структури IT-служб на підприємствах є однією з важливих сучасних тенденцій в управлінні бізнесом, інформаційними технологіями та інформаційною безпекою, тому, на думку деяких фахівців, у цих підрозділів є деякі частково взаємосуперечні інтереси і тому деякі завдання не можуть бути ефективно вирішені в рамках одного структурного підрозділу.

У складі департаменту для підвищення ефективності роботи можуть бути виділені самостійні групи (відділи), що спеціалізуються на виконанні певних функцій (рисунок 12.1):

- відділ (група, бюро) нормативної (організаційної) документації;
- відділ (група, бюро) адміністрування інформаційних систем;
- відділ (група, бюро) аудиту інформаційної безпеки;
- відділ (група, бюро) впровадження інформаційних систем і систем захисту інформації.

Рисунок 12.1 – Приклад організаційної схеми Департаменту інформаційної безпеки підприємства

Відділ нормативної документації вирішує завдання, пов'язані з формуванням, підтримкою і документальним забезпеченням політики інформаційної безпеки підприємства, і повинен, головним чином, включати в себе фахівців з менеджменту та бізнес-аналізу, що пройшли додаткову підготовку у сфері управління інформаційною безпекою. Також до складу такого відділу можуть входити юристи. Аналогічний кадровий склад може бути і у **Відділу внутрішнього аудиту інформаційної безпеки.** При цьому до кваліфікації співробітників Відділу нормативної документації, як правило, повинні пред'являтися набагато більш високі професійні вимоги.

Відділ адміністрування інформаційних систем, а також **Відділ впровадження інформаційних систем і захисту систем інформації,** як правило, повинні включати в себе фахівців з інформаційних технологій та засобів захисту інформації, що мають значний досвід впровадження та експлуатації корпоративних інформаційних систем.

12.3. Робота з персоналом підприємства

Практична реалізація всіх положень сформованої політики інформаційної безпеки потребують від підприємства тривалих практичних зусиль. Одним з основних і найбільш складних напрямків роботи є робота з персоналом, цілі якої:

- відбір і попередня перевірка персоналу, прийнятого на роботу (на службу);

- навчання співробітників;
- досягнення взаєморозуміння керівників і співробітників в питаннях забезпечення інформаційної безпеки;
- психологічна підготовка з метою протистояння методам т.зв. "соціальної інженерії".

Основною причиною, що визначає значущість людського фактора в загальній системі захисту інформації, є те, що при всій розвиненості сучасних засобів автоматизації інформаційні системи як і раніше представляють собою людино-машинні комплекси і їх функціонування багато в чому залежить від роботи окремих людей. Саме з цієї причини неадекватне поводження службовців підприємства з компонентами інформаційної системи може завдати серйозної шкоди інформаційній безпеці навіть при наявності детально опрацьованих політик безпеки і високоефективних програмних і апаратних засобів захисту інформації.

Початкова стадія роботи - підбір і розстановка кадрів - може мати кілька аспектів. У першу чергу, основним критерієм для призначення на певні посади, пов'язані з роботою з відомостями, які становлять державну таємницю, є отримання відповідної форми допуску. Відповідно до вимог чинних нормативно-правових актів Перелік посад, при призначенні на які необхідно оформляти спеціальний допуск, встановлюється керівником підприємства і може періодично переглядатися. Ця вимога пов'язана, з одного боку, з тим, що керівник підприємства несе відповідальність за забезпечення режиму секретності, а з іншого – з тим, що для виконання функціональних обов'язків співробітникам підприємства необхідно працювати з певними відомостями і, відповідно, мати певний рівень допуску.

Також при підборі і розстановці кадрів можуть застосовуватися і менш формалізовані методи. Це можуть бути різні методики психологічної оцінки, що включають в себе:

- аналіз мотиваційних аспектів особистості;
- оцінку психологічної стійкості особистості;
- оцінку рівня пізнавальних здібностей особистості (успішність

придбання нових знань і навичок і здатність до їх практичного застосування);

- оцінку активності особистості в досягненні поставленої мети, уміння об'єктивно оцінювати ситуацію і людей, вміння виробляти оптимальну стратегію поведінки.

Такого роду аналіз може бути необхідний як щодо фахівців і керівників, які працюють з інформацією, що підлягає захисту, у зв'язку з виконанням своїх посадових обов'язків за основним профілем роботи підприємства, так і фахівців і керівників, чиїм основним завданням є забезпечення інформаційної безпеки підприємства (аудиторів ІБ, проектувальників і адміністраторів інформаційних систем і систем захисту інформації тощо).

Крім ретельного підбору, однією з важливих основ роботи з персоналом є його навчання способам забезпечення інформаційної безпеки і безпечній роботі з інформаційними системами. Навчання і наступний контроль отриманих (наявних) знань може бути як первинним, так і повторним. У загальному випадку співробітник підприємства не може бути допущений до виконання своїх посадових обов'язків і роботі з інформаційними системами доти, поки він не пройде навчання з питань інформаційної безпеки і не буде:

- детально ознайомлений з усіма діючими на підприємстві вимогами і загальними правилами;
- повністю навчений методам і прийомам забезпечення інформаційної безпеки, необхідним для виконання його посадових обов'язків;
- ознайомлений з усіма можливими заходами відповідальності (дисциплінарної, адміністративної, кримінальної), які можуть бути до нього застосовані в разі порушення вимог, а також у випадку нанесення шкоди за його вини.

У завершенні всієї попередньої роботи співробітник повинен дати всі необхідні зобов'язання про нерозголошення конфіденційних відомостей, а також письмово засвідчити, що він повністю ознайомлений з основними положеннями політики безпеки. У процесі роботи підприємство також може проводити періодичний контроль знань і навичок, пов'язаний із забезпеченням

інформаційної безпеки з тією метою, щоб засвідчити компетентність працівників у цій сфері. Також одним з інструментів навчання може бути періодичне ознайомлення персоналу з реальними прикладами інцидентів, що недавно відбулися, пов'язаних з інформаційною безпекою. Крім того, додаткове навчання персоналу підприємства може проводитись у випадках:

- впровадження нових автоматизованих інформаційних систем;
- зміни бізнес-процесів підприємства;
- зміни вимог політик безпеки (наприклад, у зв'язку зі зміною вимог законодавства).

Необхідність додаткового навчання при впровадженні нових інформаційних систем і, зокрема, інтегрованих систем управління підприємством, як правило, може бути обумовлене появою нових функціональних можливостей програмного забезпечення і зміною процедур обробки інформації. Також доступ до інтегрованих інформаційних систем потенційно може дати доступ до раніше недоступної інформації та надати раніше відсутні можливості впливати на різні інформаційні потоки. У зв'язку з цим може виникнути потреба в тому, щоб співробітники мали додаткові зобов'язання про дотримання заходів інформаційної безпеки. Аналогічні організаційні заходи щодо забезпечення захисту інформації можуть бути необхідні і під час зміни бізнес-процесів підприємства, коли змінюється його структура, розподіл функцій між підрозділами і обов'язків співробітників, і відповідно, вносяться зміни в організаційні схеми, штатні розписи і посадові інструкції персоналу. Зміни вимог політики безпеки можуть бути пов'язані з появою нових загроз, зміною законодавчих вимог, розширенням ринків, зміною ставлення керівництва і власників підприємства до питань інформаційної безпеки та іншими факторами, - всі ці уточнення і зміни також повинні своєчасно і в повному обсязі доводитися до персоналу.

У процесі навчання певну значимість може мати роз'яснення раціональних причин, з яких підприємство застосовує саме таку політику безпеки. Це може служити як для кращого розуміння та засвоєння положень політики безпеки, так і для певної розрядки психологічної напруженості.

Окремим напрямом навчання та підвищення кваліфікації може бути розвиток у персоналу компанії навичок протидії методам т.зв. соціальної інженерії. Використання для незаконного проникнення в інформаційні системи методів соціальної інженерії пов'язано з т.зв. "людським фактором", який являє собою сукупність певних психологічних схильностей і особливостей мислення і поведінки, які властиві практично всім людям. До числа таких схильностей і особливостей можна віднести:

- нездатність адекватно оцінити небезпеку в деяких ситуаціях;
- специфічне ставлення до подій, що відбуваються рідко (притуплення уваги);
- зайва довіра і покладання на засоби автоматизації;
- схильність до маніпулювання, що ґрунтується, наприклад, на бажанні допомогти людям (у тому числі і незнайомим) або на зайвій довірі людям, одягненим в спеціальну уніформу, тощо

Саме з використанням деяких психологічних особливостей такого роду здійснюється багато найбільш успішних (для нападників) проникненнь в корпоративні інформаційні системи. Прикладами таких проникнень є ситуації, коли зловмисник:

- здійснює телефонний дзвінок, представляється адміністратором і, пославшись на певні обставини (такі як збій в системі), просить повідомити йому пароль;
- приходить в офіс в спеціальній уніформі (наприклад, у формі співробітника компанії, займається обслуговуванням і ремонтом комп'ютерів) і просить надати йому доступ до інформаційної системи;
- надсилає повідомлення електронною поштою від імені адміністратора інформаційної системи або керівництва підприємства і просить повідомити пароль або вчинити певні дії.

Велику значимість у системі заходів з подолання впливу людського фактора має повсякденна робота з персоналом. Крім навчання персоналу і застосування дисциплінарних заходів впливу, одним з основних завдань такої роботи є постійне нагадування всім співробітникам про необхідність

дотримання правил інформаційної безпеки. Конкретні способи, за допомогою яких такі нагадування можуть бути зроблені, будуть залежати від уподобань керівників підприємства, сформованої корпоративної культури, специфіки бізнес-процесів та інших обставин. Характерними способами того, як підприємство може постійно нагадувати своїм співробітникам про необхідність дотримуватися обережності, є:

- розміщення та періодична зміна (оновлення дизайну та змісту) нагадувань про необхідність дотримуватися вимог політики інформаційної безпеки на предметах, які постійно перебувають у полі зору співробітників протягом робочого дня: настінних і настільних календарях, кавових чашках, обкладинках блокнотів, настільних експонатах, ручках, олівцях та іншому канцелярському приладді;
- періодична розсилка відповідних брошур, бюлетенів і буклетів, а також повідомлень по електронній пошті;
- використання скрінсейверів, що містять відповідні нагадування;
- використання голосової пошти і гучного зв'язку для періодичної передачі повідомлень про необхідність дотримання правил інформаційної безпеки тощо

Таким чином, комплекс всіх організаційних заходів по роботі з персоналом підприємства, що включає в себе систему навчання персоналу, систему притягнення порушників до відповідальності, і постійне підтримання атмосфери відповідального ставлення до питань безпеки, повинен в певній мірі зменшити негативний вплив людського фактора на захищеність інформаційних систем і стан інформаційної безпеки.